Data privacy and security note

Team Softmax · Accel UdyamSync
Airtel SYNC 2026 · Track A · Deliverable 4 of 4

Built for the **Digital Personal Data Protection Act, 2023** and the DPDP Rules, 2025. The case data is synthetic, but we treat it as real. Personal data here means the proprietor's, partners' and signatory's details (name, phone, ID, address, GSTIN of a proprietorship). Every control below runs in the prototype, and most are covered by the 65 automated tests.

1 Who is responsible: roles under the DPDP Act

Party	DPDP role	What they may do with personal data
Accel Telecom (Accel Business)	**Data Fiduciary**	Decides the purposes and means; owns the notice, consent, retention, breach reporting and grievance duties.
UdyamSync platform, cloud host, OCR	Data Processor	Processes only on Accel's written instructions; OCR runs on our own servers, so no third-party AI ever sees document images.
Channel partners	Data Processor (by contract)	See a masked lead summary only, and only if the owner consents to partner sharing. They may not reuse it or keep copies.
WhatsApp BSP, e-sign ASP, UPI/NPCI, optional LLM	Data Processors	Each gets the minimum it needs: the phone number for messages, a signing request, a mandate. The LLM gets redacted text only.
Business owner / signatory	Data Principal	Can see, export, correct, withdraw consent and erase via the **My Data** page; grievance answered within 7 days.

2 Consent, per purpose, before any upload

- **Verification for activation:** required, because DoT licensing mandates subscriber KYC. Without it the upload API returns 403.
- **Order updates on WhatsApp/SMS:** optional, on by choice.
- **Sharing with a local partner:** optional, **off by default**. Only with it does a stalled lead reach the Partner Co-Pilot, and then as a masked summary.
- **WhatsApp win-back / marketing:** optional, **off by default**. Dropped leads are re-contacted only if they opted in. Historical leads without consent get no message until fresh consent is taken through a channel they already use. Every message carries opt-out.
- Each record stores the notice version shown. Withdrawing is as easy as giving, and KYC data is never reused for marketing.

3 Data minimisation and purpose limitation

- A GSTIN or Udyam lookup replaces typing the business details.
- **The Aadhaar number is never collected.** DigiLocker and Aadhaar e-sign return a verified yes/no plus a reference ID.
- We store the e-sign certificate reference, never the OTP.
- GSTIN, Udyam, phone and ID numbers are masked in the UI, in every API response and in logs (a redaction filter runs on every log line). Chat is stored redacted.
- Each purpose sees only its own data: KYC data is never used for marketing or for the propensity model.

4 Security controls

- Raw identifiers and document images are **encrypted at rest** (Fernet: AES-128-CBC + HMAC-SHA256; KMS-managed, rotated keys in production).
- The server re-prices and re-checks every order, so a tampered client cannot buy an ineligible product.
- Uploads must be PNG, JPEG or WEBP under 6 MB. Partner views are role-based, and every access goes to an append-only audit log.
- The LLM is guarded against prompt injection, and any ₹ amount it invents is discarded.
- Secrets live only in `.env`, never in the repo.

5 Auditable consent and breach response

- The consent ledger is append-only, **hash-chained and HMAC-sealed**: editing or deleting any record breaks the chain, and a CI test proves it.
- On a personal-data breach, Accel as Data Fiduciary informs the Data Protection Board and affected owners, as the Act requires. The audit log and the ledger give the timeline.
- The ledger is built to plug into a registered Consent Manager when that rule takes effect.

6 Storage limitation, and how it fits telecom KYC record-keeping

- **Document images** (the photos of certificates and IDs) are purged automatically **30 days after verification**, and the owner sees the date. Thirty days covers disputes and re-checks during installation. The value is a setting (`DOC_RETENTION_DAYS`), not hard-coded.
- **The KYC record itself is kept**, encrypted, for the contract term plus the retention period the telecom licence and DoT KYC instructions prescribe: masked extracted fields, the registry and DigiLocker/e-sign reference IDs, the verification verdict and timestamps. This is the subscriber record an auditor asks for. Abandoned sessions with no order can be erased at any time from My Data.

Open item for Accel's regulatory team: we have not confirmed whether the licence requires the document *image* itself, not only the verified record, to be kept for the full retention period. If it does, the image purge moves to the end of that period, with images still encrypted and every access logged. It is a single configuration change.

Prototype honesty. The GSTIN and Udyam registries, DigiLocker, e-sign, UPI AutoPay and the WhatsApp channel are **simulated** behind production-shaped interfaces: the WhatsApp screen is a WhatsApp-style web client, not the WhatsApp Business API. The optional free-tier LLM may retain prompts. That is acceptable only because all data is synthetic and redacted first. Production would use a no-training enterprise tier or a self-hosted model.

All businesses, people and identifiers in this project are synthetic.